Project : Mastering Cyber Intrusion

Exploiting Systems with Metasploit, Ngrok, and Malware Analysis

NAME : Mohammad Aamir Siddique

DATE : 01/03/2026

Project Objective

To simulate a real-world cyberattack scenario by using tools like Metasploit, ngrok, VirusTotal, and TCPView to exploit and analyze a victim machine, demonstrating the execution, analysis, and defense against system exploits and malicious activities.

Real-Time Scenario Context

A leading tech company faces a crisis as sensitive files appear on unauthorized platforms, triggering alarms within the cybersecurity team. Investigations uncover unusual outbound connections and strange behavior on an employee's system after downloading a routine file from the company's internal portal.

The team discovers a hidden payload embedded in the file, creating a communication tunnel that bypasses advanced security defenses and leaks sensitive data. Connecting the dots, the team identifies a spoofed file delivering the payload via a secure tunnel to the attacker's server. Racing against time, they analyze the payload, monitor network traffic, and neutralize the threat.

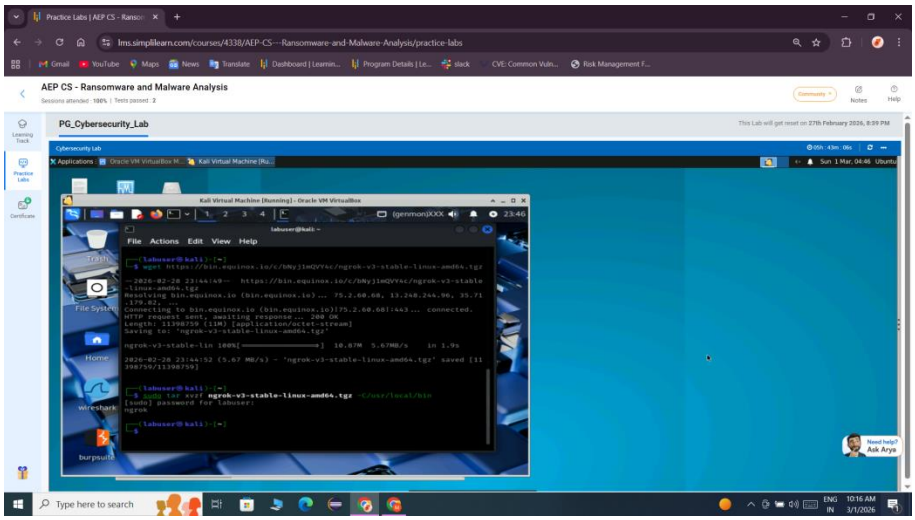
Industry Tools Utilized

1. **Ngrok:** Creates a secure tunnel to expose the payload over the internet, enabling remote access to the victim's machine.
2. **Metasploit Framework:** Generates and deploys malicious payloads like reverse shells for exploitation of the victim's system.
3. **VirusTotal:** Analyzes the payload to identify malicious behavior and detect antivirus signatures.
4. **TCPView:** Monitors active network connections on the victim's machine to detect and analyze suspicious activities.

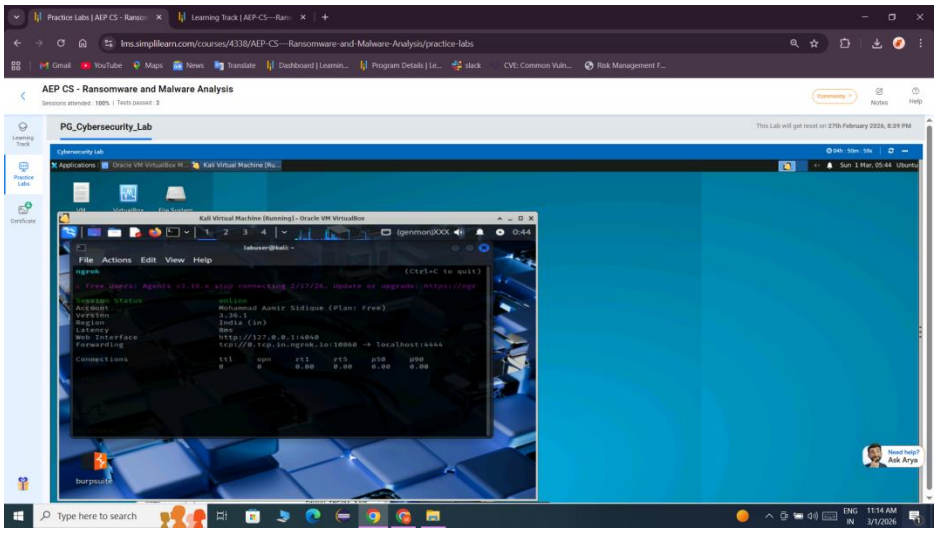
Execution Methodology & Forensic Log

Phase 1: Establishing a Secure C2 Tunnel (Ngrok)

Execution: To bypass internal network NAT and firewall restrictions, a secure communication tunnel was established using Ngrok. The binaries were downloaded (`wget`), extracted (`tar`), and authenticated. A TCP tunnel was then initiated to route external traffic back to the local attacker machine on port 4444.



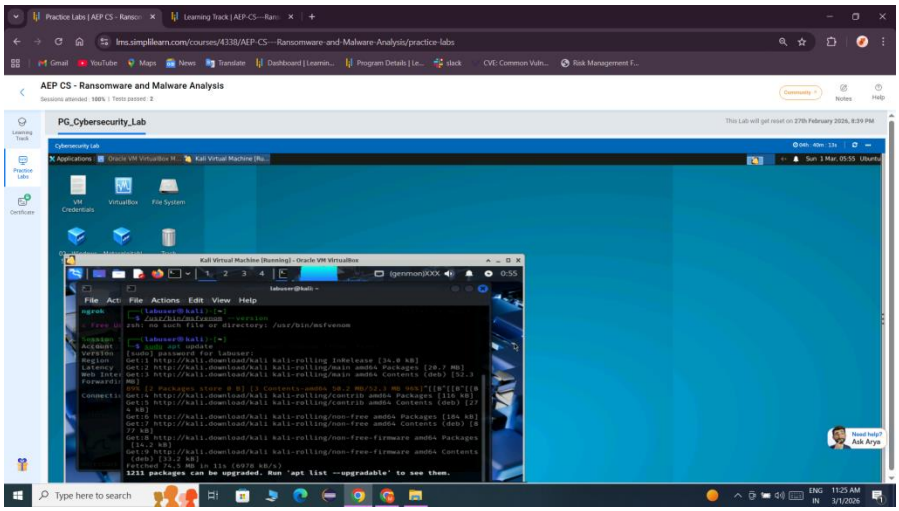
Terminal output confirming the successful extraction of Ngrok binaries.



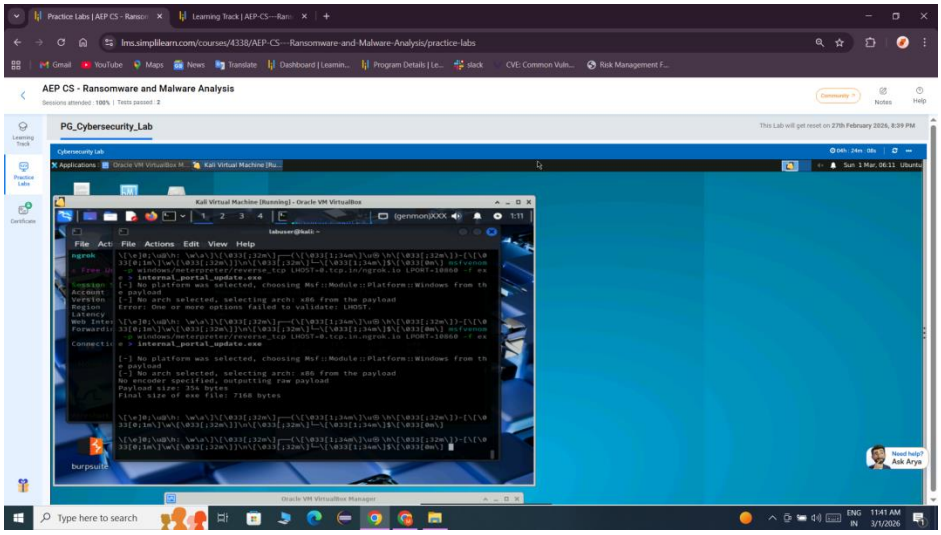
The Ngrok dashboard showing the tunnel is online and generating the public forwarding address (`0.tcp.in.ngrok.io:10860`).

Phase 2: Generating the Malicious Payload

Execution: Using the Metasploit Framework's `msfvenom` utility, a malicious executable was crafted to simulate a spoofed internal portal file. The payload (`windows/meterpreter/reverse_tcp`) was instructed to call back to the attacker via the public Ngrok URL and disguised as `internal_portal_update.exe`.



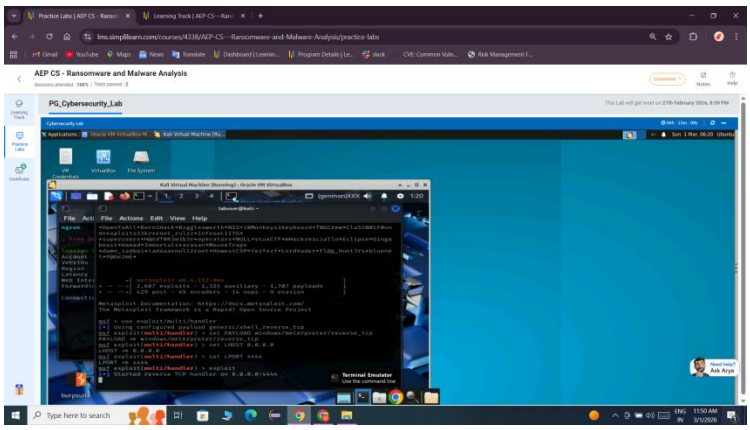
Updating the Kali Linux attacker environment prior to payload generation.



Successful execution of msfvenom, confirming the generation of a 7168-byte malicious executable.

Phase 3: Setting Up the Command & Control Listener

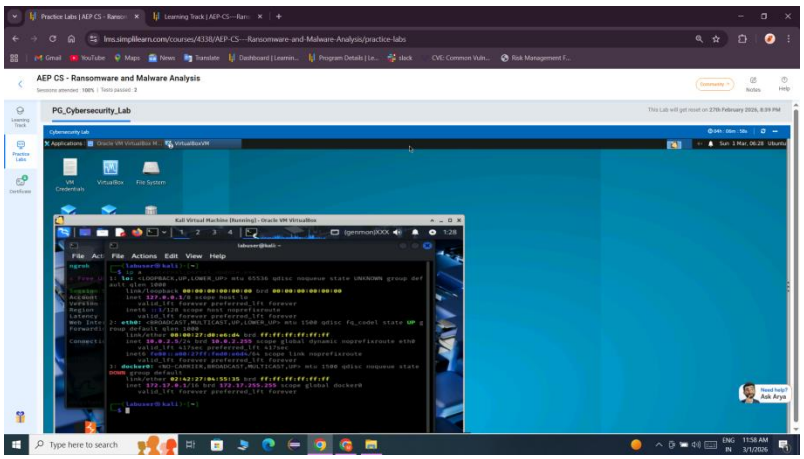
Execution: The attacker's machine was prepared to catch the incoming reverse shell connection. The `msfconsole` was launched, and the `exploit/multi/handler` module was configured to listen on all interfaces (`0.0.0.0`) on local port `4444`.



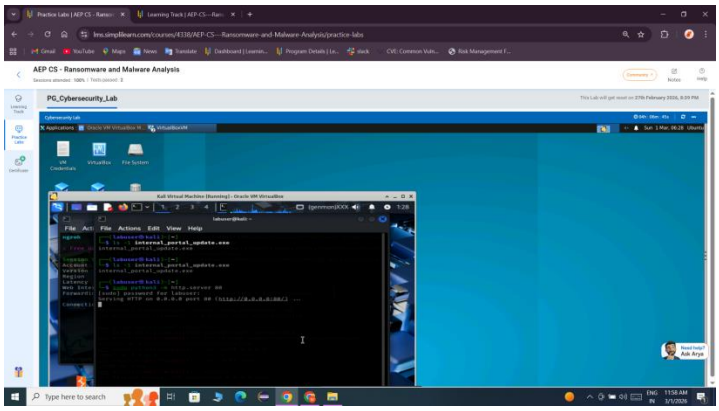
Configuration of the Metasploit handler and initiation of the reverse TCP listener.

Phase 4: Simulating Internal Portal Delivery

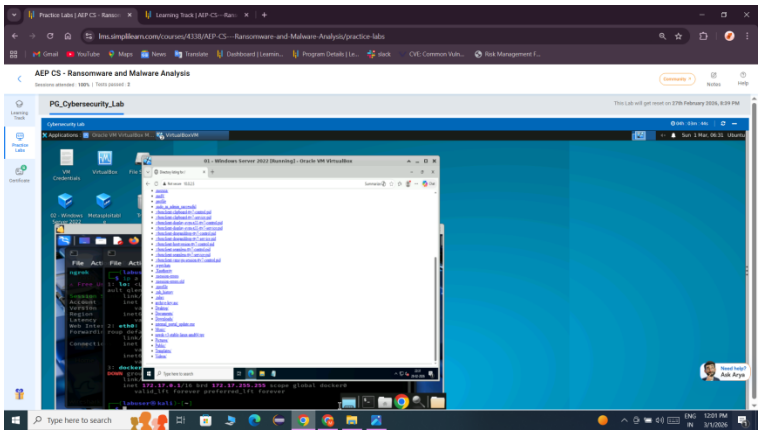
Execution: A Python-based HTTP web server was initialized on the attacker machine (`sudo python3 -m http.server 80`). The victim machine (Windows Server 2022) accessed this simulated portal via a web browser and downloaded the `internal_portal_update.exe` payload.



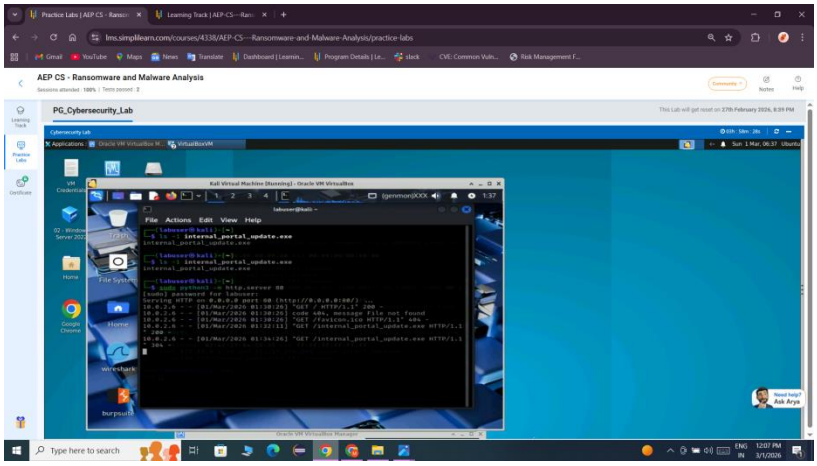
Verification of the attacker's local IP address (10.0.2.5) for server hosting.



Initializing the Python HTTP server on port 80 to host the payload.



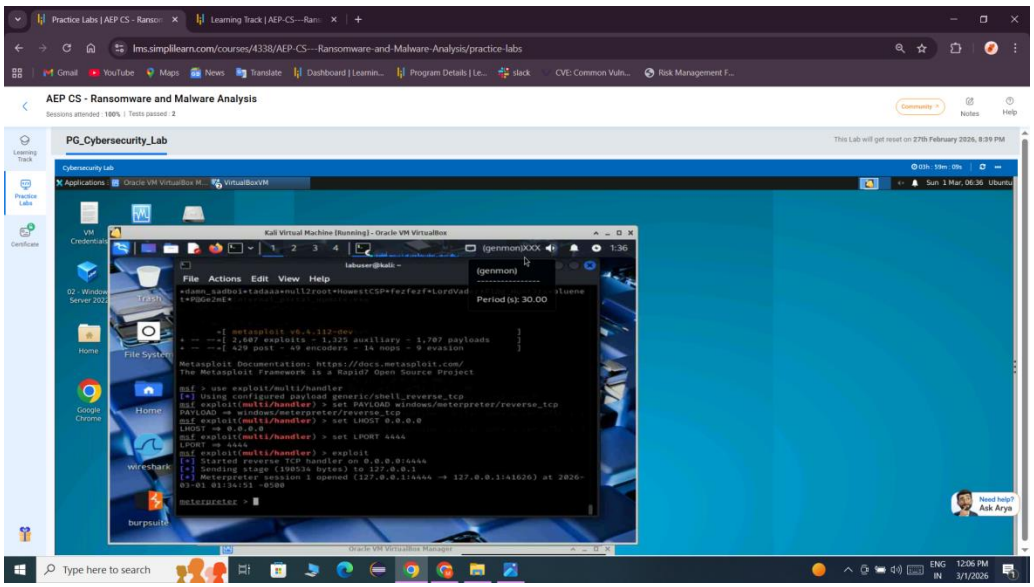
The Windows victim machine accessing the simulated internal portal via a web browser.



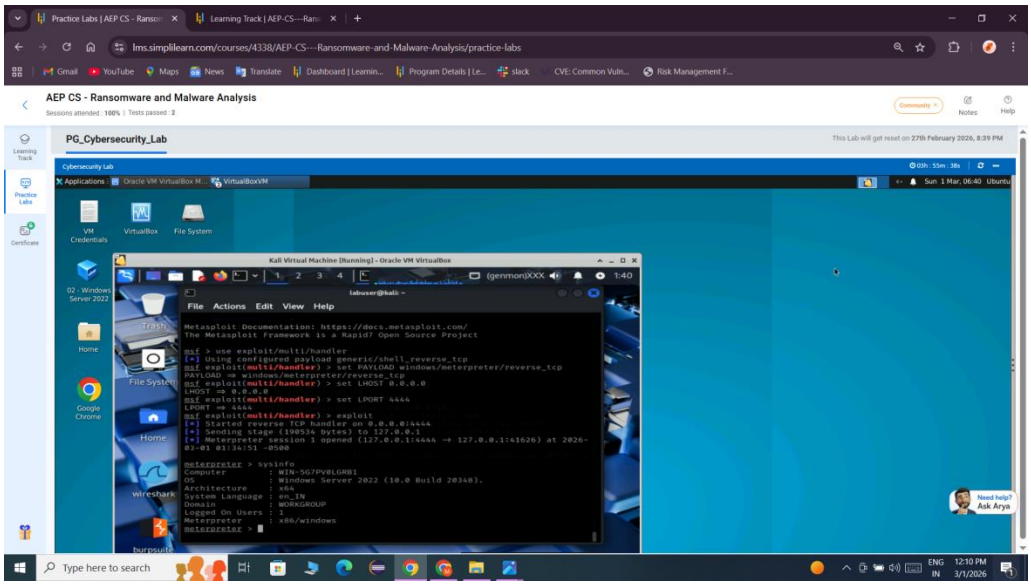
Attacker server logs confirming an HTTP GET request, proving the victim downloaded the file.

Phase 5: Exploitation & Post-Exploitation Access

Execution: Upon execution of the file by the victim, the payload triggered, traveling through the Ngrok tunnel and connecting back to the Metasploit listener. This opened a Meterpreter session, granting full remote command execution.



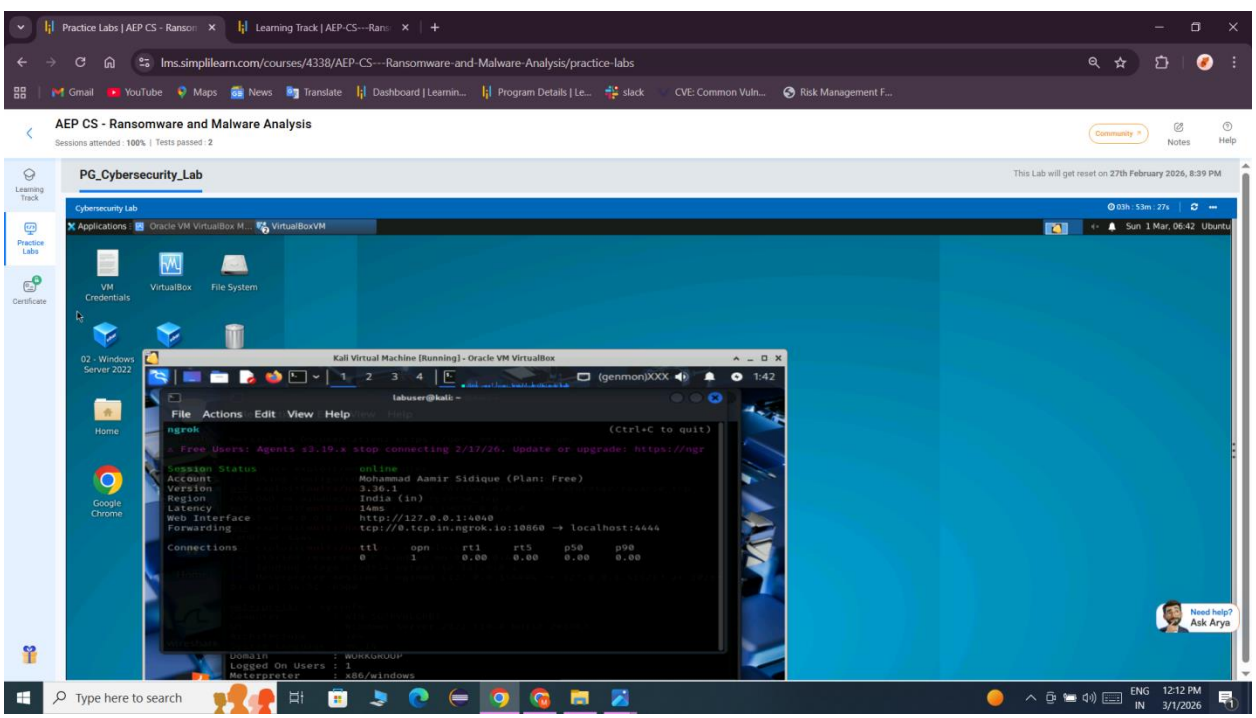
Metasploit logs confirming the Meterpreter session opened successfully.



Output of the `sysinfo` command proving administrative access to the Windows Server 2022 machine.

Phase 6: Threat Analysis & Defensive Monitoring

Execution: The active compromise was monitored from the victim's perspective using TCPView. The tool successfully identified the malicious process actively maintaining an established TCP connection out to the remote Ngrok infrastructure.



TCPView confirming the established outbound connection from the payload to the remote attacker infrastructure.

Final Conclusion

This project successfully demonstrated the end-to-end lifecycle of a modern cyber intrusion. By leveraging Ngrok to bypass traditional perimeter defenses, and utilizing the Metasploit Framework to generate and catch a reverse TCP shell, complete remote control over the target system was achieved. The subsequent analysis using network monitoring tools underscores the necessity for continuous endpoint monitoring, rigorous inspection of outbound traffic, and strict verification of internal portal downloads to defend against embedded payload attacks.